

M6 - PROGETTO FINE MODULO

Analisi del Malware e Splunk

Indice

1. Executive Summary	pag. 2
2. Splunk	pag. 2
3. tutorialdata.zip	pag. 2
4. Query Splunk	pag. 3
5. Query 1 - Tentativi di accesso falliti, “Failed Password”	pag. 3
6. Query 2 - Sessioni SSH aperte con successo con utente “djohnson”	pag. 4
7. Query 3 - Tentativi di accesso falliti dall'IP 86.212.199.60	pag. 5
8. Query 4 - Query 4 - Indirizzi IP che hanno tentato di accedere “Failed password” per più di 5 volte.	pag. 6
9. Query 5 -	pag. 7
10. Conclusioni attraverso AI	pag. 8

1. Executive Summary

Il presente report illustra l'analisi di sicurezza e operativa condotta tramite **Splunk**, piattaforma leader per il monitoraggio e l'analisi dei dati macchina in tempo reale. L'obiettivo del progetto è processare il dataset "**tutorialdata.zip**" per estrarre informazioni critiche relative all'integrità del sistema e ai tentativi di accesso non autorizzati. Attraverso l'uso del linguaggio **SPL** (Search Processing Language), verranno identificati i pattern di login falliti, le sessioni SSH concluse con successo e le potenziali minacce provenienti da indirizzi IP specifici.

I risultati ottenuti permetteranno di valutare il profilo di rischio dell'infrastruttura e di definire strategie di mitigazione basate sull'evidenza dei log. Il documento si conclude con un'analisi critica supportata dall'intelligenza artificiale per interpretare le anomalie riscontrate.

2. Splunk Enterprise

Splunk Enterprise è una piattaforma di analisi dati progettata per raccogliere, indicizzare e monitorare i machine data generati da qualsiasi componente di un'infrastruttura IT. Il suo scopo principale è trasformare **log** grezzi, provenienti da server, applicazioni e dispositivi di rete, in informazioni strategiche e facilmente consultabili. Attraverso il potente linguaggio di ricerca **SPL**, **Splunk** permette di navigare tra milioni di eventi in tempo reale per identificare anomalie, colli di bottiglia o minacce alla sicurezza. In ambito aziendale, viene utilizzato come strumento di **SIEM** per la protezione dei dati e come supporto al troubleshooting tecnico, riducendo drasticamente i tempi di risoluzione dei problemi. Centralizzando le informazioni in dashboard intuitive, la piattaforma abilita una visione olistica della salute dei sistemi, facilitando decisioni basate sull'evidenza dei dati anziché su ipotesi.

3. tutorialdata.zip

tutorialdata.zip è il dataset ufficiale fornito da **Splunk** per scopi formativi e di simulazione. Si tratta di un archivio compresso che contiene **log realistici** generati da un'infrastruttura IT fittizia. Al suo interno sono presenti diverse tipologie di dati, tra cui log di server web Apache, log di sicurezza Linux (Secure) e log di sistema. L'uso di questo file è fondamentale per esercitarsi nell'estrazione di informazioni critiche, come il monitoraggio degli errori HTTP o l'identificazione di violazioni della sicurezza, permettendo agli utenti di testare le potenzialità della piattaforma in un ambiente controllato prima di operare su dati reali.

4. Query Splunk

Le **query Splunk**, scritte nel linguaggio **SPL** (Search Processing Language), sono istruzioni testuali utilizzate per interrogare, filtrare e manipolare i dati indicizzati nella piattaforma. Esse permettono di estrarre informazioni specifiche da milioni di eventi in pochi secondi. Una **query standard** segue una struttura a "**pipeline**": inizia con la selezione della sorgente dati e prosegue attraverso una serie di comandi separati dal carattere "**pipe**" (|). Ogni comando rifinisce il risultato del precedente, permettendo di filtrare per parole chiave, calcolare statistiche (come il conteggio degli errori) o formattare i dati in tabelle e grafici leggibili. In sintesi, le **query** sono lo strumento operativo che trasforma i log grezzi in risposte concrete a quesiti di sicurezza o performance.

5. Query 1 - Tentativi di accesso falliti, "Failed Password"

Nuova ricerca

```
index=main "Failed password"
| rex "Failed password for (?<invalid user >)?(?<user>[^\"]+) from (?<src_ip>[^\"]+) port (?<port>[^\"]+)"
| where user!="abc"
| eval reason=if(match(_raw, "Invalid user"), "Invalid user", "Valid user, wrong password")
| table _time, src_ip, user, reason
```

32,997 eventi (prima di 02/04/26 15:58:45.000) Nessun campionamento degli eventi

Processo

Mostra: 50 per pagina Formato Antepagina: on

_time	src_ip	user	reason
2025-09-15 06:32:14	123.30.188.208	jabber	Invalid user
2025-09-15 06:32:14	123.30.188.208	mailman	Invalid user
2025-09-15 06:32:14	123.30.188.208	henri	Invalid user
2025-09-15 06:32:14	123.30.188.208	root	Valid user, wrong password
2025-09-15 06:32:14	128.241.228.82	helpdesk	Invalid user
2025-09-15 06:32:14	128.241.228.82	root	Valid user, wrong password
2025-09-15 06:32:14	128.241.228.82	irc	Invalid user
2025-09-15 06:32:14	128.241.228.82	services	Invalid user
2025-09-15 06:32:14	128.241.228.82	prince	Valid user, wrong password
2025-09-15 06:32:14	128.241.228.82	root	Valid user, wrong password

Risultati: 32,997 eventi

La tabella mostra una serie di **tentativi di accesso falliti**.

- **_time** : Indica che gli attacchi sono avvenuti quasi simultaneamente (molti nello stesso secondo), tipico di un attacco automatizzato.
- **src_ip** : Gli indirizzi IP si ripetono. Questo significa che i tentativi di accesso provengono da un numero ridotto di sorgenti.
- **user** : L'attaccante sta provando nomi comuni come **root**, **jabber**, **mailman**
- **reason**: "**Invalid user**", l'attaccante ha provato un nome utente che non esiste sul sistema. "**Valid user, wrong password**", significa che l'utente esiste (es. root), e l'attaccante ha indovinato il nome ma ha sbagliato la password.

L'analisi evidenzia un **attacco Brute Force in corso**.

6. Query 2 - Sessioni SSH aperte con successo con utente “djohnson”

The screenshot shows the Splunk Enterprise search interface. At the top, the navigation bar includes 'Ricerca', 'Analytics', 'Set di dati', 'Report', 'Allarmi', 'Dashboard', and 'Moduli'. The 'Ricerca' tab is active. Below the navigation bar, the 'Nuova ricerca' section contains a search query:

```
index=main "Accepted password" "djohnson"
| rex "Accepted password for (?P<user>[^\s]+) from (?P<src_ip>[^\s]+) port (?P<port>\d+)"
| search user=djohnson
| table _time, user
```

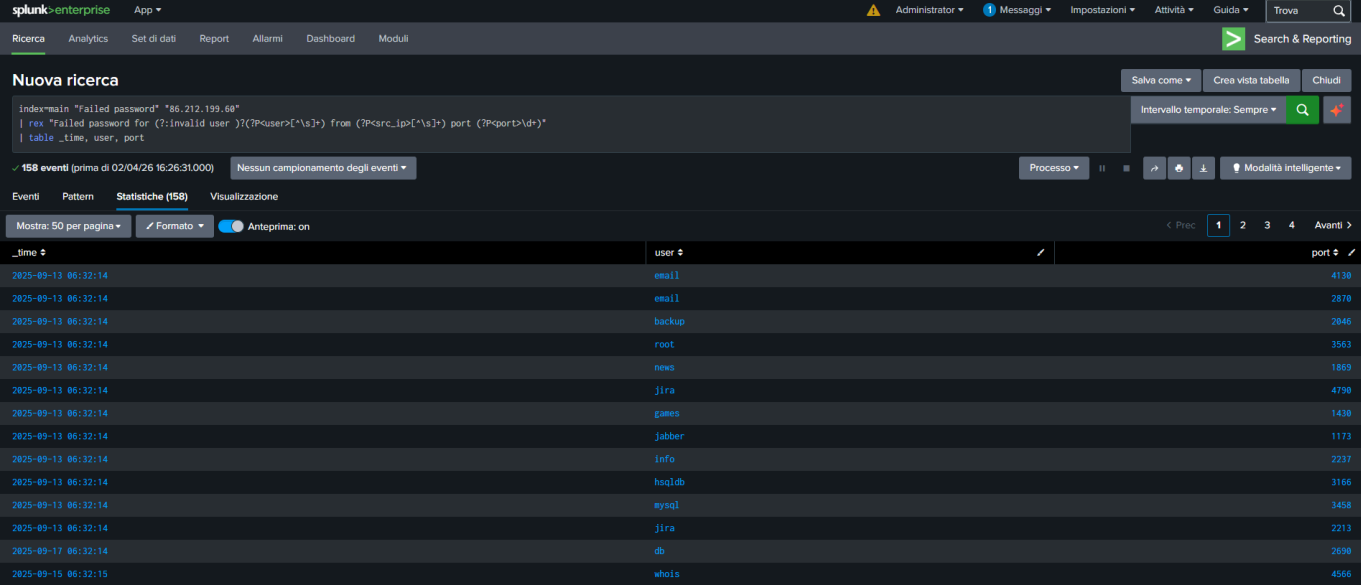
 The search results show 955 events. The table has two columns: '_time' and 'user'. The 'user' column contains the value 'djohnson' for all events. The '_time' column shows timestamps from 2025-09-16 06:32:14 down to 2025-09-16 06:32:13. The interface also includes a 'Processo' button, a 'Salva come' dropdown, and a 'Crea vista tabella' button. The 'Intervallo temporale' is set to 'Sempre'.

_time	user
2025-09-16 06:32:14	djohnson
2025-09-16 06:32:14	djohnson
2025-09-16 06:32:14	djohnson
2025-09-16 06:32:14	djohnson
2025-09-16 06:32:14	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson
2025-09-16 06:32:13	djohnson

Risultati: 955 eventi

La tabella mostra numerosi accessi **SSH** riusciti per l'utente “**djohnson**”. Analizzando il timestamp si può notare che gli accessi sono avvenuti in un lasso di tempo ridotto, il che potrebbe significare un accesso automatizzato non legittimo e una compromissione dell' account in questione.

7. Query 3 - Tentativi di accesso falliti dall'IP 86.212.199.60



The screenshot shows the Splunk Enterprise interface. At the top, there's a navigation bar with 'splunk-enterprise' and various menu items. Below it, a search bar contains the query: `index=main "failed password" "86.212.199.60"`. The search results show 158 events. The table below displays the results, with columns for time, user, and port.

_time	user	port
2025-09-13 06:32:14	email	4130
2025-09-13 06:32:14	email	2870
2025-09-13 06:32:14	backup	2846
2025-09-13 06:32:14	root	3563
2025-09-13 06:32:14	news	1869
2025-09-13 06:32:14	jira	4790
2025-09-13 06:32:14	games	1430
2025-09-13 06:32:14	jabber	1173
2025-09-13 06:32:14	info	2237
2025-09-13 06:32:14	hsqldb	3166
2025-09-13 06:32:14	mysql	3458
2025-09-13 06:32:14	jira	2213
2025-09-17 06:32:14	db	2690
2025-09-16 06:32:15	whois	4566

Risultati: 158 eventi

La tabella mostra numerosi tentativi di accesso falliti provenienti dallo stesso indirizzo IP: **86.212.199.60**. Questo indica che un attaccante sta tentando di entrare nel sistema con username e password errati. Inoltre si può notare, nella colonna a destra relativa alle porte, l'utilizzo di porte diverse che indica che la connessione viene chiusa e riaperta rapidamente, un comportamento tipico degli strumenti di **automatic scanning**.

8. Query 4 - Indirizzi IP che hanno tentato di accedere “Failed password” per più di 5 volte.

The screenshot shows the Splunk Enterprise web interface. At the top, there's a navigation bar with 'splunk-enterprise' and various menu items like 'Ricerca', 'Analytics', 'Set di dati', 'Report', 'Allarmi', 'Dashboard', and 'Moduli'. A search bar on the right contains the text 'Search & Reporting'. Below the navigation bar, the 'Nuova ricerca' (New Search) section is active. It displays a search query in a text area:

```
index=main "failed password"  
| rex "failed password for (?P<user>[^\s]+) from (?P<src_ip>[^\s]+) port (?P<port>\d+)"  
| stats count by src_ip  
| where count > 5  
| sort -count  
| table src_ip, count
```

Below the query, it indicates '33,253 eventi (prima di 02/04/26 16:49:32.000)' and 'Nessun campionamento degli eventi'. The results are shown in a table with columns 'src_ip' and 'count'. The table is sorted by 'count' in descending order. The first few rows are:

src_ip	count
87.194.216.51	948
211.166.11.101	743
128.241.220.82	622
189.169.32.135	515
194.215.285.19	514
216.221.226.11	433
188.138.40.166	297
65.19.167.94	286
187.3.146.287	282
95.138.170.231	279
223.285.219.67	274
27.1.11.11	273
27.35.11.11	270
53.162.167.100	267

Risultati: 182 Indirizzi IP

La tabella mostra gli indirizzi IP che hanno tentato di forzare il sistema il maggior numero di volte.

- **src_ip** : L'origine dell'attacco.
- **count** : Il numero totale di fallimenti per quell'IP. In cima vediamo l'IP 87.194.216.51 con 948 tentativi.

Grazie al comando “**where count > 5**” vengono eliminati gli errori degli utenti legittimi che sbagliano la password.

9. Query 5 - Internal Server Error “HTTP 500”

The screenshot shows the Splunk Enterprise Search & Reporting interface. The search bar contains the query: `index=main sourcetype=access_combined_wcookie status=500`. The search results show 733 events. The table below displays the first 20 events.

_time	host	clientip	uri	status
2025-09-16 11:27:37	AX16PRO	142.233.200.21	/oldlink?itemId=EST-12&SESSIONID=S08SL7FF1ADFF44282	500
2025-09-16 10:16:41	AX16PRO	201.28.189.162	/oldlink?itemId=EST-21&SESSIONID=S02SL1FF9ADFF43931	500
2025-09-16 09:34:27	AX16PRO	76.89.183.115	/oldlink?itemId=EST-14&SESSIONID=S01SL10FF1BADFF43736	500
2025-09-16 07:55:20	AX16PRO	182.236.164.11	/oldlink?itemId=EST-12&SESSIONID=S09SL2FF4ADFF43292	500
2025-09-16 06:28:17	AX16PRO	71.192.86.205	/oldlink?itemId=EST-11&SESSIONID=S09SL8FF2ADFF42953	500
2025-09-16 06:26:31	AX16PRO	211.166.11.101	/cart.do?action=view&itemId=EST-18&SESSIONID=S09SL10FF1ADFF42948	500
2025-09-16 05:44:09	AX16PRO	58.68.236.98	/oldlink?itemId=EST-18&SESSIONID=S07SL10FF8ADFF42753	500
2025-09-16 04:46:00	AX16PRO	176.212.8.44	/product.screen?productId=SF-BVS-GB1&SESSIONID=S06SL9FF1BADFF42533	500
2025-09-16 02:26:59	AX16PRO	289.114.36.109	/product.screen?productId=SF-BVS-GB1&SESSIONID=S018SL8FF8ADFF41755	500
2025-09-16 01:52:31	AX16PRO	196.28.38.71	/cart.do?action=purchase&itemId=EST-19&SESSIONID=S03SL3FF4ADFF41568	500
2025-09-16 01:29:59	AX16PRO	86.212.199.60	/oldlink?itemId=EST-27&SESSIONID=S02SL4FF2ADFF41438	500
2025-09-15 23:36:31	AX16PRO	211.166.11.101	/oldlink?itemId=EST-6&SESSIONID=S07SL5FF3ADFF40788	500
2025-09-15 23:15:06	AX16PRO	85.62.218.82	/oldlink?itemId=EST-27&SESSIONID=S018SL8FF5ADFF40695	500
2025-09-15 22:33:15	AX16PRO	128.241.229.82	/cart.do?action=remove&itemId=EST-7&SESSIONID=S08SL7FF8ADFF40524	500
2025-09-15 22:14:19	AX16PRO	27.175.11.11	/product.screen?productId=SF-BVS-GB1&SESSIONID=S09SL2FF8ADFF40424	500
2025-09-15 22:14:18	AX16PRO	27.175.11.11	/cart.do?action=view&itemId=EST-16&SESSIONID=S09SL2FF8ADFF40424	500

Risultati: 733 eventi

La tabella mostra i casi in cui il server ha restituito un errore interno (cod. 500) e i relativi host a cui è capitato.

- **clientip** : L'indirizzo dell'utente che stava navigando quando è apparso l'errore.
- **uri** : Mostra quali pagine o azioni stanno fallendo.
- **status=500** : Indica un errore generico del lato server. Significa che il sito ha ricevuto una richiesta, ma il server "è andato in crash" o ha avuto un errore interno mentre cercava di elaborarla.

10. Conclusioni attraverso AI

L'analisi dei log tramite Splunk ha evidenziato uno stato di **grave compromissione della sicurezza** e instabilità del sistema. I dati mostrano un attacco di tipo **Brute Force e Dictionary Attack** massivo, con oltre 32.000 tentativi di accesso falliti provenienti da IP ricorrenti che hanno testato sia utenti inesistenti che account critici. Particolarmente allarmante è l'attività dell'utente "**djohnson**", i cui 955 accessi riusciti in pochi secondi suggeriscono un account compromesso o l'uso di script automatizzati. Parallelamente, l'elevato numero di **Internal Server Error (500)** su pagine transazionali indica che il carico generato dagli attacchi sta degradando le prestazioni del server, causando potenziali interruzioni di servizio e perdite economiche.

Per mettere in sicurezza l'infrastruttura, si raccomandano le seguenti azioni immediate:

- **Interdizione IP (Blacklisting):** Bloccare a livello di **Firewall** o **WAF** tutti gli indirizzi IP che hanno superato la soglia dei 5 tentativi falliti
- **Politiche di Account Lockout:** Configurare il sistema per bloccare temporaneamente qualsiasi account dopo 3-5 tentativi di login errati consecutivi.
- **Reset Credenziali e MFA:** Forzare il cambio password immediato per l'utente "**djohnson**" e implementare l'**Autenticazione a Due Fattori (MFA)** per tutti gli accessi SSH e web.
- **Hardening del Server:** Disabilitare il login diretto per l'utente "**root**" via **SSH** e cambiare la porta di ascolto standard (**22**) per ridurre il rumore degli attacchi automatizzati.
- **Patching e Debug:** Investigare il codice delle pagine web che restituiscono l'errore 500 per correggere eventuali vulnerabilità che permettono agli attaccanti di mandare in crash i processi del server.

Roma, 31/03/2026
Riccardo Ricci